

Marco Integrativo GQM+PRAGMATIC para Indicadores de Ciberseguridad KEV

1. Introducción: ¿Por qué combinar GQM y PRAGMATIC?

Cuando se habla de indicadores nacionales de ciberseguridad, especialmente en el ámbito de las Known Exploited Vulnerabilities (KEV), es fácil caer en la tentación de medir por medir. El resultado suelen ser tablas llenas de cifras que nadie sabe interpretar y que, en el mejor de los casos, sirven para rellenar presentaciones. El problema no es la falta de datos, sino la falta de **trazabilidad clara** entre lo que queremos lograr, lo que preguntamos y lo que medimos.

GQM (Goal-Question-Metric) proporciona esa trazabilidad: desde un objetivo estratégico hasta métricas concretas, pasando por preguntas que guían el camino. **PRAGMATIC**, por su parte, asegura que esas métricas sean útiles: Predictivas, Relevantes, Accionables, Genuinas, Significativas, Precisas, Oportunas, Independientes y Rentables.

Juntos, GQM y PRAGMATIC forman un marco que no solo dice **qué medir**, sino **por qué y para qué**. En este documento se describe cómo aplicar este marco integrativo a los indicadores nacionales de KEV propuestos para España, con miras a un sistema de evaluación de madurez que sea a la vez riguroso y práctico.

2. Fundamentos de GQM (Goal-Question-Metric)

2.1 Origen y propósito

GQM nació en el ámbito de la ingeniería de software (Basili y Rombach, 1980s) como un método para definir métricas que realmente sirvan para algo. Su lógica es de una simplicidad devastadora:

1. Goal (Objetivo): ¿Qué queremos conseguir? Debe ser específico, medible y alineado con la estrategia.
2. Question (Pregunta): ¿Qué necesitamos saber para saber si vamos hacia el objetivo? Las preguntas desglosan el objetivo en aspectos manejables.
3. Metric (Métrica): ¿Qué medimos para responder cada pregunta? Las métricas son datos concretos, pero siempre al servicio de una pregunta, que a su vez alimenta un objetivo.

2.2 Aplicación a indicadores KEV nacionales

En el contexto de KEV, un objetivo nacional podría ser:

Objetivo (G1): *Reducir la exposición nacional a vulnerabilidades explotadas conocidas, minimizando el tiempo medio de remediación y su impacto en incidentes críticos, alineado con NIS2 y ENS.*

De este objetivo derivarían preguntas como:

- P1.1: ¿Cuántas organizaciones españolas tienen KEV abiertas?
- P1.2: ¿Con qué rapidez se remedian las KEV críticas?
- P1.3: ¿Qué porcentaje de incidentes graves está vinculado a KEV?

Y cada pregunta se traduce en métricas:

- M1.1: % de organizaciones con ≥ 1 KEV expuesta (E1).
- M1.2: Mediana de días de remediación KEV (R1).
- M1.3: % de incidentes de gravedad alta asociados a KEV (I1).

Así, QQM asegura que cada indicador que se mide responde a una pregunta estratégica, y no es un número suelto en el vacío.

3. Fundamentos de PRAGMATIC

PRAGMATIC es un acrónimo de nueve criterios para evaluar la calidad de una métrica. Fue popularizado en el libro *PRAGMATIC Security Metrics* (W. Krag Brotby y Gary Hinson, 2013) y es especialmente útil para filtrar métricas que son teóricamente atractivas pero prácticamente inútiles.

Los criterios son:

4. Predictive (Predictivo): ¿La métrica nos ayuda a predecir el futuro? Una métrica predictiva permite anticipar problemas, no solo lamentarlos.
5. Relevant (Relevante): ¿Importa a quienes toman decisiones? Si el CEO o el Ministro no le encuentra sentido, la métrica morirá de indiferencia.
6. Actionable (Accionable): ¿Si la métrica cambia, podemos hacer algo al respecto? Una métrica que no desencadena acción es un adorno.
7. Genuine (Genuino): ¿Es difícil de manipular o falsear? La confianza en los datos es esencial.
8. Meaningful (Significativo): ¿Refleja algo importante? «Número de CVEs totales» es grande, pero ¿es significativo? No tanto como «% de KEV parcheadas en plazo».
9. Accurate (Preciso): ¿Es razonablemente exacta? No se pide perfección, pero sí que el error sea asumible y conocido.
10. Timely (Oportuno): ¿Llega a tiempo para actuar? Una métrica de 2024 en 2026 es una curiosidad histórica, no una herramienta de gestión.
11. Independent (Independiente): ¿Es independiente de otros indicadores? Evita redundancia y duplicidad.
12. Cost-effective (Rentable): ¿El coste de obtenerla es razonable frente a su valor? No tiene sentido gastar 100.000€ en medir algo que solo aporta 5.000€ de valor.

3.1 Puntuación PRAGMATIC

Cada criterio se puntúa de 0 a 10. La suma da una puntuación total (0-90). Como regla general:

- **>70**: Métrica excelente, prioritaria.
- **50-70**: Métrica buena, adecuada.
- **<50**: Métrica problemática, revisar o descartar.

4. Integración GQM+PRAGMATIC: el proceso paso a paso

Paso 1: Definir el objetivo estratégico (Goal)

Ejemplo: «Reducir la exposición nacional a KEV y acelerar la remediación, alineado con NIS2 y ENS, para mejorar la resiliencia digital del país».

Paso 2: Descomponer en preguntas (Questions)

- Q1: ¿Cuál es la exposición actual?
- Q2: ¿Qué tan rápido actuamos?
- Q3: ¿Qué impacto tienen las KEV en incidentes?

Paso 3: Definir métricas candidatas (Metrics)

Para Q1: % de organizaciones con KEV, densidad media de KEV por organización, etc.

Paso 4: Evaluar cada métrica con PRAGMATIC

Aplicar los nueve criterios y puntuar. Si una métrica queda por debajo de 50, reformularla o sustituirla.

Paso 5: Seleccionar y priorizar métricas

Quedarse con las métricas mejor puntuadas, asegurando cobertura de todas las preguntas clave.

Paso 6: Diseñar la recogida de datos

Definir fuentes (escáneres, SIEM, registros de incidentes, encuestas), frecuencia y responsables.

Paso 7: Implementar y monitorizar

Poner en marcha, revisar periódicamente si las métricas siguen siendo PRAGMATIC y ajustar.

5. Ventajas del enfoque integrado

- Trazabilidad completa: desde la estrategia nacional hasta el dato técnico, sin saltos lógicos.
- Calidad asegurada: solo métricas que cumplen criterios de utilidad práctica.
- Comunicación clara: permite explicar por qué se mide cada cosa, en lenguaje de negocio y de técnica.
- Mejora continua: el propio marco permite revisar y refinar métricas periódicamente.

6. Cierre

El objetivo de este marco no es complicar la vida, sino **hacerla más sencilla** evitando la medición por inercia. Con GQM+PRAGMATIC, cada indicador KEV nacional que se proponga debe superar una doble prueba: ¿responde a una pregunta estratégica real? ¿Y es útil, creíble y asequible?

Si la respuesta es "sí" en ambos casos, la métrica tiene derecho a existir. Si no, es mejor dejarla en la lista de «cosas que mediríamos si tuviéramos tiempo y dinero infinitos», que es donde pertenecen la mayoría de las métricas que adornan informes y no cambian decisiones.

Y recuerde: «lo que no se puede medir, no se puede gestionar» es una verdad a medias. Lo que realmente no se puede gestionar es lo que **medimos mal, interpretamos peor y comunicamos fatal**. GQM+PRAGMATIC intenta salvarnos de ese destino.